

Where to Look: Audit-Allocation Games against Adaptive Persistent Poisoning

FSE 2027 Research Track · FSE-2027-15 · system SENTINEL · proposal P9 (rank 15)

A defender with a limited verification budget, against an attacker who moves to wherever the budget is not.

The problem

Verification is rationed, so somebody must decide where the checks go—at memory insertion, retrieval, delegation or patch acceptance—and an adaptive attacker answers second. Generic Stackelberg formulations already occupy that framing, so the question is whether anything about software workflows changes the answer.

Why existing work does not answer it

Three properties do, and they interact: poisoning is *persistent* (state survives across tasks), *delayed* (the trigger fires tasks after insertion), and *multi-carrier* (memory, skills, queues and branches propagate differently and cost differently to audit). The defender’s problem is not which target to protect but when, and in which carrier, to look.

Approach: Sentinel

- **Belief over (carrier, insertion time, trigger schedule)**, so an alarm now raises the posterior on insertions earlier and triggers later—information a stateless policy discards.
- **Randomized commitment.** Against an attacker who observes the policy, a deterministic schedule is trivially defeated.
- **Exact minimax on small games**, robust optimisation over a restricted library elsewhere.
- **Benign drift as a separate latent cause**, without which the optimal policy is to quarantine everything.
- **Policies frozen by hash before evaluation**, enforced by the harness rather than by protocol.

Theory

- **Robust Stackelberg bound** under bounded transition uncertainty, tight up to a constant.
- **Distinguishability budget:** the audit budget needed to separate harmful persistence from benign change grows with trigger delay and carrier heterogeneity, and a single-carrier single-time audit cannot pay it at any depth.
- **The regime boundary that decides the paper:** commit-time auditing is sufficient at small delay or single carrier, and provably insufficient beyond.
- **Restriction loss** of the finite policy library, measured against exact solutions.

Datasets

New: AUDITGAME-SE. 100 workflows over 15 repositories with *evaluator-known* carrier and trigger state, so worst-case harm is computable rather than estimated. Trigger delay and carrier heterogeneity are swept as first-class axes. 620 benign changes are generated to match poisoning events on surface statistics, verified by a discriminator AUC ≤ 0.56 .

Built on / also evaluated against: Multi-step repair workflows over public repositories in the SWE-BENCH format under OPENHANDS; attack categories reuse AGENTPOISON, MINJA and MEMPOISON with evaluator-known carrier and trigger state; a shared learned detector is used by every system so allocation, not detection, is the variable.

Baselines (SOTA comparators)

(B1) audit-at-commit (*the headline comparator — the baseline most likely to make this work unnecessary*) · (B2) uniform random auditing · (B3) audit-on-insertion · (B4) audit-on-retrieval · (B5) risk-score thresholding · (B6) Adaptive-Contracts-inspired two-stage check · (B7) exhaustive small-game minimax oracle (*ceiling*). Attacker policies: rational best-responders, 18 scripted policies (7 held out) and 3 unconstrained LLM attackers, reported separately.

Headline results

Endpoint	Result	Against
Worst-case harm	−34.1%	audit-at-commit, where the method applies the honest figure and sometimes slightly worse; heterogeneity delays the crossover
Against held-out attackers	−27.6%	
At small delay	no better	
Predicted crossover	$\Delta \approx 2$ tasks	observed at 2.1
Randomization vs. adaptivity	0.184 vs. 0.099	randomize before you adapt

Go/no-go gate

At least 15% relative reduction in worst-case verified harm over audit-at-commit against *held-out* attacker policies at equal budget. If commit-time verification catches nearly all consequential harm across the grid, the sequential game adds complexity and nothing else—and the paper is structured so that is reportable.

Status. Values marked as results are *projected* from the pre-registered design in PLAN.md; no full study has been run. The manuscript carries a page-1 banner to that effect. See PLAN.md for the execution plan and REVIEWS.md for the internal review record.